

Fraud Risk Assessment Toolkit for Archives

A guide for those completing the assessment

Version 0.5 · Shaffer and Co · September 2026

What this is

A self-administered fraud risk assessment designed specifically for archive services. It helps you see where your service may be exposed to fraud risk, both from within the service and from people outside it making false claims about who they are or what they are entitled to.

You work through it at your own pace, involving whoever in your organisation you need to. Nobody comes to inspect you, and there is no pass mark.

Completed assessments can be anonymously combined to build an evidence-based picture of fraud prevention across UK archives, which has never existed. Your service is not identifiable in that picture.

What it is not

- It is not an audit, an inspection, or a test. Nobody is marking it.
- It is not a security assessment. It sits alongside the ARA Security Guidance rather than duplicating it.
- It is not an IT or cyber assessment. Questions about firewalls, patching and passwords are deliberately absent: they are covered better elsewhere, and for most services they sit with a parent authority.
- It does not ask you to name individuals, and you should not do so anywhere in it.

Who should complete it

One lead respondent, usually the head of service. Some questions will sit outside your direct knowledge, particularly around finance, IT, buildings and HR, so consult colleagues where you need to. There is an optional question for recording who contributed.

If your service sits inside a larger organisation, some answers may need a call to the parent authority. Those questions are written so that Don't know is a legitimate answer if the information genuinely sits elsewhere and you cannot readily get it.

What to have to hand

You do not need any of this to start, and you can save and return. But gathering it first makes the profile section much quicker:

- Staff headcount and FTE, on TNA Sector Survey definitions
- How long the head of service has been in post, and the longest-serving current staff member
- Volunteer numbers, and where they work
- Collection extent, in whatever measure you normally use, plus approximate digital holdings
- Number of sites holding collections
- Your policy list, and where each policy comes from: your own, a parent authority's, or both
- The date of the last internal audit, and whether it runs on a cycle
- Terms of deposit, or equivalent
- Your deaccessioning and disposal policy, if you have one
- Details of any externally funded or hosted posts, including who manages them and what oversight applies
- Your income streams, and whether cash is involved

- Whose procurement rules apply, and any value threshold for competitive tender
- Any register of interests, and any gifts and hospitality policy or register, whether yours or your parent authority's

How long it takes

[To be confirmed by timed pilot completion. The previous estimate predates a substantial expansion of the question set and should not be relied on.]

You do not need to do it in one sitting. Save and return as often as you like; each section is a natural break point.

Before you begin

One suggestion. Take a walk through your own premises with fresh eyes before you start. Informal practices matter as much as anything written down: the propped-open door, the fob that gets loaned, the visitor who is waved through because everyone knows them. Those are the things the assessment is trying to surface, and they are easier to notice on a deliberate walk than from a desk.

Three things to read before you touch a cell

Don't know is a real answer

It is offered deliberately throughout, and it is different from No. An honest Don't know is one of the most useful things this assessment can capture, because it shows you where to look first. As one pilot participant put it: you don't know what you don't know, and this process is designed to surface it.

Answer as things are, not as they should be

The assessment only works if it reflects what actually happens day to day, rather than what the policy manual says. A flattering self-portrait helps nobody, least of all you. Nothing here is scored against a standard, and there is no benefit to looking good.

Do not enter personal data

Refer to roles, not names. "A long-serving volunteer" rather than anyone identifiable. This applies to every free-text box in the workbook.

How it works

The assessment has two parts.

Part one builds a profile of your service: its structure, people, collections, premises, governance and finances. Many questions are conditional, so you will only see those that apply. If you have no volunteers, you will not be asked about volunteer supervision.

Part two presents a set of risk scenarios and asks you to rate each one. Which scenarios you see depends entirely on your part one answers. You will only ever be asked about situations that apply to your archive, and a service with strong controls throughout may see very few.

This is worth stressing: the number of scenarios you see is not a score. It reflects the shape of your service as much as the state of your controls. A service with volunteers, placements, a reading room and cash income has more surfaces than one with none of those, regardless of how well it manages them.

Part two: the scoring

Each scenario is rated on three dimensions. The first two will be familiar from any risk register; the third may not be.

Dimension	Scale	What it asks
Likelihood	Rare · Unlikely · Possible · Likely · Almost certain	How likely is this, in your service, as things actually stand?
Impact	Negligible · Minor · Moderate · Significant · Severe	If it happened, how bad would it be? Financial loss is only part of this: reputational damage, loss of depositor confidence and irreplaceable material all count.
Confidence	Documentary record · Oral or personal recollection · Educated guess · Not confident at all	How do you know? Not how sure you are of your rating, but what your rating rests on.

Confidence is the dimension people find unfamiliar, and it is the one that makes this assessment useful rather than decorative. Rating something as unlikely on the strength of an educated guess is a different finding from rating it unlikely because you checked the log. Both are legitimate answers. Recording which one you are giving is the point.

Likelihood and impact are drawn from the Public Sector Fraud Authority's Full Fraud Risk Assessment Practice Note, reworded for an archive context. The confidence hierarchy comes from ISA (UK) 500 on audit evidence, with a fourth level added for the honest case where you have nothing to go on.

Likelihood and impact combine into a risk rating on a five by five matrix. You do not need to calculate anything; the workbook does it.

The scenarios

There are twenty-three in total. You will see only those your profile answers make relevant:

- Shared services
- Returning ex-staff privileges
- Volunteer supervision and access
- Placement vetting and supervision
- Externally funded and hosted posts
- Mandatory leave and cover

- Leaver access revocation
- Cataloguing backlog
- No catalogue
- Closed records with sensitive data
- Volunteer access to closed records
- Portable high value items
- Depositor identity and authority
- Researcher identity verification
- Deaccessioning and disposal
- Catalogue and record integrity
- Independent audit
- Fraud response readiness
- Conflicts of interest
- Gifts and hospitality
- Separation of duties
- Donation and gift acceptance
- Cash handling

What you will be asked

The full question set follows, section by section. Conditional questions are included, so you will not necessarily see all of them. Free-text boxes for additional notes appear at the end of every section and are always optional.

A. Assessment details

Who is completing the assessment, in what capacity, and who else you consulted. This is also where you record any similar self assessments the service has already done, so that overlapping work can be recognised rather than repeated.

A1 Name of archive service

A2 Date assessment started

A3 Role of lead respondent

A4 In what capacity is the lead completing this?

A5 Who contributed or was consulted? (optional) First select role, then functional area, if applicable

A6 Which similar self-assessments has the service completed?

B. Classification

How the service is governed and what it can rely on from a parent body. These answers shape much of what follows: a service with a parent authority's HR, IT and audit functions is in a different position from an independent trust that has none of them.

B1 Archive type

B2 Nation

B3 Governance structure

B4 Does a parent authority or institution provide central functions, e.g. HR, IT, audit, policies?

B4.1 Which functions?

B5 Is structural change expected or definite within 3 years, e.g. local government reorganisation, merger, relocation?

B6 Which scalability type does your service fall under, and how was that determined?

C. Premises and physical access

Who can get into the building and into the secure areas, how that access is controlled, and what happens when something goes wrong. Shared premises get particular attention: the pilot showed front of house security running to the landlord's hours rather than the archive's, and council staff and contractors holding fobs to archive space.

C1 Are your premises standalone or shared?

C1.1 Who provides front-of-house security, and do its hours match archive opening hours?

C1.2 Is there a documented access agreement with co-occupants, and when was it last reviewed?

C1.3 Can any non-archive personnel access secure areas, e.g. maintenance, cleaning, emergency call-out, and what protocols apply?

C2 How is access to secure areas controlled? (fobs or cards, keys, keypads, biometric, none)

C2.1 Does the head of service hold a complete, current list of everyone with access?

C2.2 Are access logs produced, and are they reviewed?

C2.3 When were access rights last reviewed, and what came of the most recent review?

C2.4 If the access system fails, do doors fail locked or open, and is a maintenance SLA in place?

C3 Number of sites holding collections

C4 Is there intruder detection or alarm coverage, and how is it monitored?

C5 Is there a documented procedure for reporting security incidents, who is it reported to, are incidents logged, and is the log reviewed?

D. People

Staff, volunteers, placements, contractors and externally funded posts. The section is long because most fraud risk in a small organisation is about who has access to what, and on what terms. Several clusters appear only if they apply to you: no volunteers means no volunteer questions.

D1 Paid staff: headcount and FTE (TNA Sector Survey definitions)

D2 Years the current head of service has been in post, longest-serving current staff member, and number of staff who predate the current head

D3 Is there a documented knowledge-transfer or succession process when long-serving staff leave?

D4 Volunteers: how many, and in which settings (public areas, staff areas, secure areas), and what supervision applies in each

D4 Are written volunteer agreements in place? Is volunteer access logged?

D4 Do former staff return as volunteers, and are their permissions reset to volunteer level?

D4 Do any volunteers serve on the governing body, and do any of them also volunteer operationally?

D4 Do volunteers work remotely, what do they access, do they use individually named accounts, and is their access logged?

D5 Does the service host work experience placements?

D5.1 How many placements have you hosted in the last 12 months?

D5.2 Which of the following are in place before or on the first day of a placement?

D5.3 In which settings are placements allowed, and what supervision applies?

D6 Are any posts funded from outside the core budget, e.g. grants, hosted projects, secondments?

D6.1 How many such arrangements do you currently have?

D6.2 For each arrangement: funding source, line management, oversight (project board, funder reporting, other), and whether HR, Finance and Procurement processes match those for core staff

D7 Contractors: who procures them, are they supervised in secure areas, and is an appointment protocol enforced?

D8 What pre-employment checks apply to staff?

D9 Counter-fraud awareness training: is it available, who undertakes it, when was it last run, what proportion of staff are up to date, and is the content archive-specific or generic?

D10 Mandatory leave and cover, for roles with financial authority or privileged system or records access: does policy require a minimum period of continuous annual leave, and does someone else genuinely perform or review those duties during any absence?

D11 Leavers, however they leave: is there a documented process for notifying whoever removes system and account access; the same for building access; is removal confirmed rather than assumed; and is the access list periodically checked against current staff?

E. Collections and catalogue

What you hold, what you know about what you hold, and who can get at it. The catalogue matters here as much as the strongroom: if the record of what you hold is incomplete, alterable or lost, a loss cannot be detected and could not later be evidenced.

E1 Collection extent: what measure do you use, and the figure

- E2** Is there a cataloguing backlog? Does a basic listing exist for uncatalogued accessions, and how is access to uncatalogued material handled?
- E3** What form does the catalogue take? Are paper or spreadsheet records backed up? Who authorises access to item-location data? Are holdings ever checked against location records?
- E4** Does the archive hold closed records containing sensitive personal data, and what staff and volunteer access applies to them?
- E5** Do collections include high-value, easily portable content, e.g. signatures, stamps, small drawings, single sheets?
- E6** Are depositors asked for ID plus evidence of authority to deposit, and do your Terms of Deposit require verification of authority?
- E7** Does the service operate a reading room? Which controls operate? Is original proof of identity and address checked before access, and are staff aware that identity documents, including AI-generated forgeries, can look highly convincing?
- E8** Does digitisation involve third-party or commercial partners? Do royalty or income arrangements exist? Approximate size of digital holdings
- E9** When material is returned to a depositor or donor, is the identity and authority of the person collecting it verified?
- E10** Is there a documented deaccessioning and disposal policy, approved by senior management?
- E11** Does disposal of an accessioned item require approval from the governing body?
- E12** Does disposal of non-accessioned material require agreement from more than one authorised person?
- E13** Is a record kept of each disposal, including reference number, date, method, and authoriser?
- E14** Is that record independently reviewed?
- E15** Catalogue and record integrity: does the system record who changed each record and when; can records be permanently deleted; how long is the change history kept; and could you establish what you held from a separate copy if the system were lost?

F. Policies, oversight and audit

What is written down, who approves it, who checks it, and what happens when something is suspected. This section also covers declarations of interest and gifts and hospitality, both of which may be governed by a parent authority's arrangements rather than your own.

- F1** For each of security, collections and access, volunteers, social media, IT, data protection, fraud response or whistleblowing, and conduct and ethics: does a policy exist and what is its source?
- F2** Who approves archive-specific policies, and are they reviewed after adoption?
- F3** When was the archive service last subject to internal audit? Is this part of a regular cycle, at what frequency, are any unannounced, and which areas?
- F4** Are accounts externally audited?
- F5** Do staff know how to report suspected fraud?
- F6** Is there a documented point at which a reported incident is escalated to a formal fraud referral?
- F7** Once fraud is suspected, are staff told not to read, write to, or delete the system or records in question without authorisation?
- F8** Are staff aware that alerting a suspected individual before an investigation is secured could itself be an offence?
- F9** Declarations of interest: registers for the governing body and for staff; when signed declarations including nil returns were last collected; whether the form covers close family and personal connections; whether decision records show a declared interest and its treatment; whether private

collecting, dealing or personal research use must be declared; and whether a governing body member who also volunteers is excluded from related decisions

- F10** Gifts and hospitality: whether a policy and a register exist; whether a value threshold is set; whether the policy covers suppliers, depositors and donors, and researchers and users; and whether archival material offered personally is treated as an offer to the service

G. Finance and income

Budgets, payments, income streams, cash and procurement. Small services will legitimately rely on compensating controls rather than full separation of duties, and the section is written to record that rather than to penalise it.

- G1** Does the archive hold its own budget, and who is the budget holder?
- G2** Can any one person both raise and authorise the same payment? Before a payment is authorised to a new or changed bank account, is this independently checked?
- G3** Where duties cannot be fully separated, what compensating controls apply?
- G4** Which income streams does the service have? For donations: is the donor's identity checked above £25,000 or where a donation looks unusual, and are staff aware of red flags?
- G5** Is cash handled? Is it recorded at the point of collection, counted by someone other than the collector, reconciled by someone other than the collector, and how often is it banked?
- G6** Whose procurement rules apply? Is there a value threshold for formal competitive procurement, is it documented and known, and must those involved declare personal or family connections to a supplier?

What you get at the end

On completion you will have, within the workbook itself:

- A profile of your service, in a form that can be reused for other purposes
- The set of risk scenarios your profile identified as relevant, each with the specific answers that raised it
- Your own likelihood, impact and confidence ratings for each, and a risk rating derived from them

This is stages one to three of a nine-stage process. The later stages, which produce a heat map, a mitigation plan, a summary report suitable for a management team, a risk register and a residual risk view, are in development and are not part of this version. What you receive from this pilot is the assessment itself and your own scores, not a finished management report.

That is worth saying plainly rather than discovering at the end.

Your data

Your completed assessment belongs to your service. Where results are combined to build the sector picture, your service name and any identifying details are removed first.

A separate privacy notice covers this in full. If anything you encounter while completing the assessment indicates dishonesty or serious misconduct by an identifiable individual, a Schedule 1 Appropriate Policy Document under the Data Protection Act 2018 governs how that is handled; ask for a copy if you would like to see it before starting.

What happens next

Return the completed workbook as agreed. Findings across all pilot sites are compiled anonymously, and participating services receive the pan-sector picture that results.

If you get stuck on a question, or think one is unanswerable as written, say so. During the pilot that is at least as useful as the answer itself.